

Изпълнете следните стъпки, за да сте защитени в интернет:

- Използвайте само надеждни сайтове, когато предоставяте личната си информация.
- Винаги проверявайте URL адреса. Ако сайтът включва https://, тогава може да му се има доверие и той е защитен. Ако URL адресът е http:// и липсва последната буквичка "s", избягвайте да въвеждате информация като пароли, лични данни, номера на вашата кредитна или дебитна карта и др.
- Внимавайте с имейлите. Не отваряйте прикачени файлове към електронната поща и не кликувайте върху връзки в имейли от неизвестни източници. Един от най-честите начини, по които хората са атакувани, е чрез имейли, прикрити добре като изпратени от някого, на когото имате доверие. Това най-често са банки и платежни институции като PayPal, E-pay и т.н.
- Винаги актуализирайте софтуера на устройствата си. Актуализациите на софтуера съдържат важни корекции и подобрения за отстраняване на проблеми със сигурността. Най-голям успех престъпниците имат в остарели устройства, защото те не притежават актуални защити за сигурността.
- Използвайте силни пароли. Дългите, случайни и сложни пароли правят много по-защитено вашето лично пространство в интернет. Използвайте мениджър на пароли. Той може да съхранява вашите сложни пароли, без да се налага да ги помните.

Уеб сигурност

Комуникациите през интернет са отворени и неконтролирани. Това предполага голямо разнообразие от възможни атаки. За да се обезпечи сигурността на информацията, е необходимо да се избегне неототоризираният достъп до уеб данните.

Уеб сигурност е защита на информацията срещу достъп, използване, разкриване, увреждане, промяна, преглед, запис или изтриване от неупълномощени потребители.

Повечето заплахи при интернет могат да се класифицират в една от следните четири категории:

- Загуба на целостта на данните – нарушителят добавя, модифицира или изтрива информация.
- Загуба на конфиденциалност на данните – информацията става достъпна за неототоризирани потребители.
- Загуба на услуги – дадени услуги не могат да се изпълняват в резултат от действията на атакуващия.
- Загуба на контрол – услугите се използват от ототоризирани потребители по неототоризиран начин.

Срещу нормалното функциониране на уеб сайтове има насочени различни атаки:

- **DoS атаки** (англ. Denial of Service – отказ на услуга) – водят до отказ в обслужването. Те са проектирани да направят една машина или мрежов ресурс недостъпни за потребителите. Най-често са атакувани уеб сървъри, като целта е те да станат недостъпни от интернет.

Атаката може да бъде чрез изтощаване на ресурси или чрез възползване от грешка в софтуера на жертвата. По време на такива атаки рязко се повишава разходът на ресурси на процесора и намалява пропускателната възможност на канала за свързване, което може да доведе до силно забавяне на работата на цялата компютърна система, на отделни задачи или изобщо към пълно спиране на обслужването. По този начин уеб сайтовете, работещи на даден сървър, не могат да се зареждат в уеб пространството.

Защитата срещу такива атаки се осъществява със специализиран софтуер, ограничаващ броя на IP адресите, които изпращат неограничен брой заявки към сървъра за зареждане на сайта. Този софтуер обикновено се инсталира на малък сървър.

- **Sniffing атаки** (англ. Sniffing – подушване) се използват за събиране или прихващане на данни чрез улавяне на мрежовия трафик с помощта на приложение, насочено към улавяне на мрежови пакети. Ако пакетите данни, които се предават през мрежата, не са криптирани, те могат да бъдат прочетени от това приложение. По този начин нападателят може да анализира мрежата и да получи информация, с която мрежата да се срине или да се повреди, или да прочете комуникациите, случващи се в мрежата.

- **IP Spoofing** (англ. Spoofing – измама) включва промяна на заглавието (хедъра) на IP пакети на изпращаните съобщения. Това ги кара да изглеждат така, сякаш идват от IP адрес, различен от реалния адрес на първоизточника. Целият поток от данни към и от даден компютър или мрежов сегмент може да бъде пренасочен да минава през определен компютър – компютъра на атакуващия. Така потокът от информация може да бъде преглеждан, претърсван и подправян. IP Spoofing представлява метод за придобиване на неототоризиран достъп до компютър или мрежа за започване на атака, за кражба на данни или за унищожаване на данни.

Рискове при използване на бисквитки и уеб маяци

HTTP бисквитка (англ. HTTP cookie) – това е съвсем малък по размер файл, който се създава и изпраща от уеб сайта (сървър) и се записва от уеб браузъра на потребителя в системното му пространство. При всяка следваща заявка, направена от браузъра към същия уеб сайт, информацията от бисквитката се изпраща към сървъра. Бисквитките се използват от уеб сайтовете, за да "различават" и "запомнят" своите посетители, регистрирани или гости, да запомнят предпочитанията на потребителите и състоянието на дадена функционалност, услуга или особеност в сайта.

Бисквитките може да са сесийни (session cookie) или постоянни (persistent cookie). Сесийните са временни и се изтриват при затваряне на браузъра. Из-

ползват се за запомняне на текуща информация при сърфиране в сайта – продукти в кошницата, разпознаване на потребител, временни настройки. Постоянните бисквитки се съхраняват от браузъра за определен срок, зададен при създаването им. Подходящи са за запомняне на потребителски настройки и данни, необходими при следващи посещения на сайта.

При атака срещу бисквитките достъпът до тях би дал възможност за кражба на потребителски данни от съответните сайтове. Друг вид атака, насочена срещу бисквитките, е "отравянето" им. Атакуващият може да "инжектира" код чрез модификация на съдържанието на бисквитките, като по този начин осъществява постоянни атаки срещу уеб сайта.

За защита от атаки срещу бисквитките трябва да се спазват инструкциите за тяхното управление и предпазване от неоторизираното им използване от трети страни, които всеки браузър предлага на потребителите си. Потребителят може да изтрие по всяко време, да позволи или да забрани използването на бисквитки. За да направи това, трябва да промени настройките за поверливост на своя браузър.

Уеб маяк – това е малко графично изображение, което изследва уеб активността на потребителя. Той често се съдържа в прозрачно графично изображение с размери 1x1 пиксела, намиращо се в имейл или уеб сайт. Когато потребител посети уеб сайт или изпрати имейл, съдържащ уеб маяк, се записва информация за потребителя (за аналитични цели). Тази информация може да съдържа например IP адрес, по кое време е посетена страницата, тип на устройството, кой браузър е използван, и др. Често се използва в комбинация с бисквитки.

Уеб маяците могат да бъдат открити в HTML кода на уеб страница при търсене в таговете . За разлика от другите изображения, те се зареждат от друг сървър.

За да спрат това проследяване, много от приложенията за електронна поща не показват изображения по подразбиране.

Сертификат за сигурност

С цел защита на връзката, осъществявана от потребителите към уеб сайтове, са създадени различни криптографски протоколи. Най-разпространените са **SSL** (Secure Sockets Layer) и неговият наследник **TLS** (Transport Layer Security). Те се използват, за да криптират данните, и защитават канала, по който се извършва комуникацията между уеб браузърите и уеб сървърите, където са разположени сайтовете. Така всички данни, които преминават от браузъра на клиента до определен уеб сайт, са криптирани и защитени.

За осъществяването на сигурна криптирана връзка между клиента (уеб браузър) и сървъра е необходимо на сървъра да бъде инсталиран **SSL/TLS сертификат**. Този сертификат е предназначен за всеки, който иска да защити комуникацията на потребителите към уеб сайта.

Сертификатът се състои от публичен ключ и допълнителна информация. Допълнителната информация може да бъде името на домейна, името на фирмата и друга информация в зависимост от типа на сертификата. Публичният ключ се изпраща на браузъра, който проверява дали сертификатът е валиден и се уверява дали уеб сървърът е този, за който се представя.

Процесът по криптиране на връзката (фиг. 1) започва, когато потребителят се опита да отвори един сайт. Тогава неговият браузър прави заявка към сървъра, а той му връща отговор. Вече получил отговор, браузърът на потребителя проверява информацията за наличен сертификат. Използвайки данни от сертификата, браузърът генерира произволен код, който криптира с публичния ключ на сървъра и го изпраща към сървъра. Той от своя страна го декриптира и заедно с браузъра предприемат нужните стъпки за генериране на финален ключ за криптиране, с който се шифрова цялата комуникация помежду им.

Пред домейна на всеки сайт със сертификат има изобразен зелен катинар или в съкращението "https://" пред адресното поле. Уеб сайтове без SSL/TLS сертификат биват отличени с "http://".

Съществуват две категории сертификати:

- Безплатни (self sign) – при зареждането на сайта браузърите показват съобщение, че сайтът може да съдържа потенциален риск за данните на клиента. Този тип сертификати обикновено се използват по време на изграждане-то и тестването на уеб сайт, но не са добър избор за реална работа на сайта.

Основни понятия

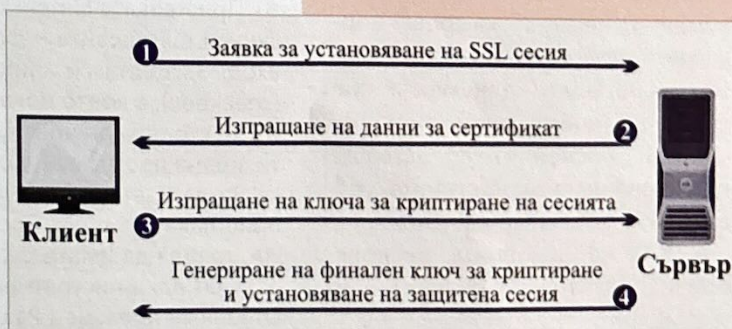
Бисквитка – малък по размер файл, който се създава и изпраща от уеб сайт, когато се зарежда, към уеб браузър.

Уеб маяк – малко графично изображение, което изследва уеб активността на потребителя.

Публичен ключ за сигурност (САРСНА) – тест за сигурност, използван да се определи дали потребителят на дадена система е човек, или компютър.

Сертификат за сигурност – технология за криптиране на данни и защита на канала, по който се извършва комуникацията между клиент и сървър.

Допълнителна функционалност (Plug-in) за защита – независимо компилиран софтуерен модул, който се инсталира в допълнение към уеб браузъра.



Фиг. 1. Процес по криптиране на връзка

Издаването на сертификат се осъществява чрез заявка **CSR** (Certificate Signing Request) – искане за подписване на сертификата. CSR обикновено се генерира на сървър, където ще бъде инсталиран SSL/TLS сертификатът, и съдържа информацията, която ще бъде включена в сертификата, като име на организация, име на домейн, местоположение, държава. Сертифициращият орган ще използва CSR, за да създаде SSL/TLS сертификат.

За повишаване на сигурността в интернет съществуват различни процедури, чрез които се свързва определен публичен ключ (фиг. 2) с идентичността на неговия собственик (титуляр). Свързването се гарантира от сертифициращия орган чрез строго установен процес на регистрация и издаване на съответен сертификат.

Същността на теста се състои в това – компютър генерира прост въпрос, чийто отговор е лесен за човек, но не и за друг компютър. Например потребителят въвежда символите, показани на фигурата (букви/цифри), но по такъв начин, че машинното разпознаване на текста е много трудно. Според общоприетите стандарти за достъпност до интернет на хора със зрителни увреждания такъв тест трябва да бъде допълнен от вариант, базиран на разпознаване на реч (аудиотест). Има и тестове, където трябва да изберете правилната снимка от списъка.

Средства за повишаване сигурността на уеб сайт

- Обновяване на използваните скриптове, кодове, разширения, платформи, софтуер.

- Редовно архивиране на сайта.
- Постоянно сканиране на уеб сайта и сървъра.
- Инсталиране на приставки за допълнителна защита.
- Инсталиране на SSL/TLS сертификат.
- Управление на администрацията на уеб сайта чрез силни пароли, налагане на ограничения за възможни входни точки за злонамерени лица.
- Проверка на мрежата от страна на сървъра и от страна на клиента.
- Използване на специализирани инструменти за проверка на сигурността.

Приставката Simple Google reCAPTCHA се използва за защита на различни форми в уеб сайта – форма за регистрация, коментар, забравена парола и вход. За целта се кликва в кутийка (checkbox), с което показвате на сайта, че сте реален човек, а не автоматизирана програма – робот (фиг. 3).

- От административния панел избирате **Разширения/Добавяне на още**. Отваря се прозорец **Разширения**.

- Въвеждате в полето за търсене името на плъгина Simple Google reCAPTCHA.
- След визуализацията на приставката щраквате върху **Install Now/Activate** и трябва да следвате съответните стъпки.



Фиг. 2. Примери за публични ключове

Въпроси и задачи

1. Защо е нужно да се обръща внимание на уеб сигурността?
2. Изгответе кратък текст за документ за някоя атака срещу нормалното функциониране на уеб сайт. Споделете документа със своите съученици в интернет.
3. Кои са основните средства за повишаване сигурността на уеб сайт?
4. Кои са основните рискове при използване на бисквитки и уеб маяци?

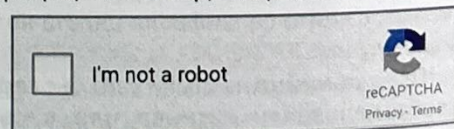


Fig. 3

Основни рискове за ползване на CMS

При работа със системите за управление на уеб съдържание (CMS) с отворен код потребителят получава изходния код на програмата и свободата да прави каквото поиска с него и с програмата. Потребителят получава права да изпълнява програмата за каквато и да е цел, да изучава как тя работи и да я променя за своите нужди, да разпространява нейни копия, да я подобрява и да публикува промените.

Основният недостатък на CMS с отворен код е лесното намиране на пропуски в сигурността, ако кодът на сайта се знае. Това отваря потенциалните рискове за сигурността и уязвимости. Други рискове при работата на CMS са липсата на обучение и сертифициране на специалисти, участващи в нейното изпълнение и техническата ѝ поддръжка. Тези системи в повечето случаи нямат директна поддръжка.

Предимствата на CMS с отворен код са, че имат голяма база от потребители и повече хора работят върху софтуера, поправят бъргове, създават модули и нови, по-добри версии. Всичко това гарантира високо качество на кода.

Атаките се дължат на факта, че приложенията, създадени със CMS, имат приблизително еднаква архитектура, което улеснява създаването на автоматизирани сканиращи атаки. Използването на слаби пароли и/или уязвими приставки привлича достъпа на зловреден софтуер.

Основни начини на защита на CMS

- Защита на административния панел. Този начин се използва, ако опцията за регистрация на нови потребители не е активна. Защитата се задава чрез ограничаване на достъпа до администрацията само за определени IP адреси и задаване на допълнително потребителско име и парола в административния панел.

- Промяна на потребителското име и парола за достъп до административния панел. При първоначалната инсталация на системата се задава парола и потребителско име по подразбиране. Редовно променяйте паролата за достъп до администрацията. Използвайте пароли, които съдържат малки и големи букви, цифри и специални символи.

Задача. Сменете паролата, чрез която системата WordPress ви дава достъп до администраторския панел при първоначалната регистрация.

- Редовно архивиране на сайта.
- Актуализиране на инсталираните приставки, теми, джаджи и др. софтуер.

- Задаване на коректни права на файлове и директории.

- Проверка на логовете за достъп. Логовете са текстови файлове, съдържащи информация за всеки посетител на сайта, както и информация за качените, свалените и изтритите файлове посредством FTP сървър.

- Да не се инсталират плъгини със сходна функционалност. Добавяйте нов плъгин само ако сайтът и посетителите имат нужда от нова функционалност и няма друг начин, по който тя да бъде активирана на сайта. При ползването на допълнителни плъгини имайте предвид, че може да възникне конфликт с някой конкретен плъгин или тема на вашия сайт. Затова, преди да инсталирате и активирате плъгин, препоръчително е да направите архив на сайта.

- Осигуряване на достатъчно ресурси на сайта, които да отговорят на неговите нужди – достатъчно дисково пространство, трафик, едновременно заявки към сървъра и др.

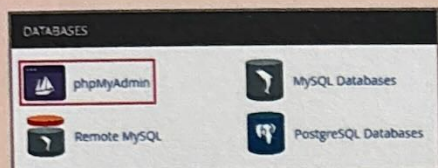
- Проверка на потребителите, които се регистрират в сайта. За целта добавете във формата за регистрация CAPTCHA код.

- Избор на авторитетен хостинг доставчик. Такъв доставчик ще ви предостави непрекъсваемост на хранване и мрежова свързаност, постоянен достъп до вашите уеб страници, повишаване на сигурността, удобен за управление администраторски панел и др.

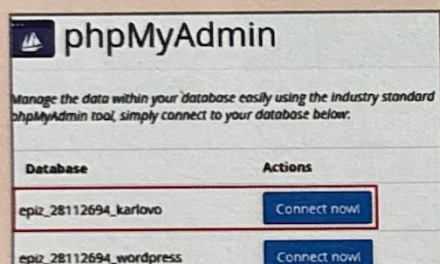
- Добавяне на допълнителни инструменти за защита.

Въпроси и допълнителни задачи

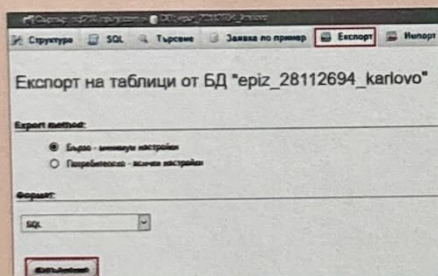
1. Кои са основните рискове при ползване на CMS?
2. Кои са основните начини за защита на CMS?



Фиг. 1



Фиг. 2



Фиг. 3

Въпроси и задачи

1. Кои са основните причини, които могат да доведат до загуба на информация?
2. Изгответе кратък текстов документ за програма, която позволява да се синхронизира уеб сайтът така, че да има огледално копие на съдържанието на сървъра и хард диска. Споделете документа със своите съученици в интернет.

Резервно копие на сайт

Информацията, която един уеб сайт съдържа, включва всички страници, публикации, коментари, връзки, изображения, мултимедия, които се намират в него. Ако тези данни се изтрият или развалят, има риск да се изгуби всичко, което се съдържа в тях. Поради това задължителна част от поддръжката на всеки уеб сайт е създаването на негово **резервно копие/бекъп** (англ. backup). В този процес данните се копират на външен носител с цел възстановяване до първоначалното им състояние в случай на повреда или унищожаване.

Има различни причини, които могат да доведат до загуба на информация:

- Експлоатационни повреди в уеб сървъра, мрежата, носителите на информация, свързани с лоша администрация, изчерпване на ресурсите и др.
- Бедствия, причинени от природата и човека – бури, земетресения, кражби, пожари. Поради това резервни копия на данните могат и е препоръчително да се съхраняват и в облачното хранилище за данни.
- Проблеми, свързани със сигурността – добавяне на софтуер, който умишлено разваля информация.
- Човешки фактор – умишлено или неволно унищожаване на важна информация.

Инструменти за създаване на резервно копие на сайт в система за управление на уеб съдържание WordPress

Преди да се правят промени по даден сайт или във връзка с подsigряване на неговата сигурност, е добре да се създаде негово резервно копие. При възникване на проблем то може да бъде върнато и сайтът ще продължи своята нормална работа.

Процесът по създаване на резервно копие на уеб сайт в система за управление на уеб съдържание WordPress се състои от две части – архивиране и създаване на резервно копие на файловете и на базата данни.

1. Създаване на резервни копия на файлове

Има различни методи за създаване на резервни копия на файловете на уеб сайта:

- Хостинг компаниите осигуряват специализиран софтуер за създаване на резервни копия.
- Наличие на програми, които позволяват да се синхронизира уеб сайтът така, че да има огледално копие на съдържанието на сървъра и хард диска. Пример за такива програми са 2Bright Sparks's Synchronback и WinSCP.
- Периодично копиране на файловете от сайта в папка на локалния компютър.

Сваляне на копие на файловете на уеб сайт се извършва от контролния панел на уеб хостинга, като от файловия му мениджър се сваля на локалния компютър или на друг носител папката, която съдържа файловете, изграждащи уеб сайта.

2. Създаване на резервно копие на база данни

Когато трябва да се направи промяна само в базата данни, без да се променят файловете на сайта, може преди това да се направи архив и копие само на базата данни. В системата WordPress резервно копие на базата данни на сайт може да се направи с помощта на уеб приложението phpMyAdmin.

PhpMyAdmin е уеб приложение с открит код, написано на езика PHP, и представлява интерфейс за администрация на системата за управление на база данни (СУБД) MySQL.

- Приложението phpMyAdmin трябва да стартираме от контролния панел на уеб хостинга (фиг. 1).
- От списъка с бази данни (фиг. 2) избираме тази, на която ще правим копие.
- В главния прозорец на приложението phpMyAdmin избираме бутон **Export**, за да се зареди прозорецът за управление на архива (фиг. 3). Настройките по подразбиране са за създаване на архив в **SQL** формат, който лесно може да бъде импортиран и/или редактиран. За да се стартира копирането, натискаме бутон **Изпълнение** и избираме място за запазване на файла във файловата система на локалния компютър.

1. Бисквитка е:

- А) малък по размер файл, който се изпраща от уеб сървър към клиентския браузър при посещение на сайт и може да съдържа информация за потребителя
- Б) малко графично изображение, което изследва уеб активността на потребителя
- В) технология за криптиране на данни и защита на канала, по който се извършва комуникацията между клиент и сървър
- Г) независимо компилиран софтуерен модул, който се инсталира в допълнение към уеб браузъра

2. Малко графично изображение, което изследва уеб активността на потребителя, се нарича:

- А) сертификат за сигурност
- Б) бисквитка
- В) плъгин
- Г) уеб маяк

3. Допълнителна функционалност (плъгин) за защита е:

- А) малко графично изображение, което изследва уеб активността на потребителя
- Б) тест за сигурност, използван да се определи дали потребителят на дадена система е човек, или компютър
- В) независимо компилиран софтуерен модул, който се инсталира в допълнение към уеб браузъра

4. Публичен ключ за сигурност (CAPTCHA) е:

- А) малък по размер файл, който се изпраща от уеб сървър към клиентския браузър при посещение на сайт и може да съдържа информация за потребителя
- Б) тест за сигурност, използван да се определи дали потребителят на дадена система е човек, или компютър
- В) технология за криптиране на данни и защита на канала, по който се извършва комуникацията между клиент и сървър
- Г) малко графично изображение, което изследва уеб активността на потребителя

5. Технологията за криптиране на данни и защита на канала, по който се извършва комуникацията между клиент и сървър, се нарича:

- А) бисквитка
- Б) допълнителна функционалност за защита
- В) публичен ключ за сигурност
- Г) сертификат за сигурност

6. Какво представляват DoS атаките в уеб пространството:

- А) използват се за събиране или прихващане на данни чрез улавяне на мрежовия трафик с помощта на приложение
- Б) водят до отказ в обслужването, правят една машина или мрежов ресурс недостъпни за потребителите
- В) включват промяна на заглавието (хедъра) на IP пакети на изпращаните съобщения

7. Атаки, които се използват за събиране или прихващане на данни чрез улавяне на мрежовия трафик с помощта на приложение, се наричат:

- А) DoS
- Б) Sniffing
- В) IP Spoofing

8. Кой от изброените начини НЕ се отнася за защита на системите за управление на уеб съдържание:

- А) редовно архивиране на сайта
- Б) защита на административния панел
- В) инсталиране на антивирусна програма
- Г) проверка на потребителите, които се регистрират в сайта

9. За извършване на проверка на потребителите, които се регистрират в сайта, е нужно:

- А) да не се инсталират плъгини със сходна функционалност
- Б) да се променят потребителското име и паролата за достъп до административния панел
- В) да се актуализират инсталираните приставки, теми, джаджи
- Г) да се добави CAPTCHA код